AuditSphere Roles & Access — End-User Guide

This guide explains every user role in AuditSphere, what each role can and cannot do, how separation of duties works, and how to tell us which work email addresses should hold each role.

1. What we need from you

Action Required: After reading this 10-minute guide, please reply with the **exact Microsoft sign-in work email address** for each person in your firm or client finance team who needs access, using the 9-column request table in Section 9 (or the companion CSV file `auditsphere-security-template-role-assignment-request.csv`).

- **Where to send your completed list:** `[insert recipient email / secure onboarding inbox, e.g., auditsphere-access@example.com]`
- **Target reply deadline:** `[insert target date, e.g., DD Month YYYY by 17:00]`
- **Non-negotiable separation-of-duties rule:** Every person who prepares work (audit procedures, trial-balance mappings, adjustment journals, financial packages, or firm invoices) **must have a different person** assigned to review or approve that work. One person cannot approve their own preparation, even if granted two roles.

2. 60-second overview

AuditSphere separates internal staff delivery from external client collaboration across **two distinct portals**:

- **Staff Workspace (`/app`):** For internal firm partners, managers, auditors, client accountants, commercial relationship managers, firm finance staff, and administrators.
- **Client Portal (`/portal`):** For external client finance contacts (`ClientUser`) to upload Provided by Client (PBC) audit documents, reply to queries, and respond to proposed management adjustment journals and financial packages.

Everyone signs in with their **Microsoft work account (Microsoft Entra ID)**. Signing in proves identity, but opens nothing until an AuditSphere **Administrator** records a **Role Grant** combining a **Role** (what they do) and a **Scope** (which clients, engagements, or consolidation groups they may access).

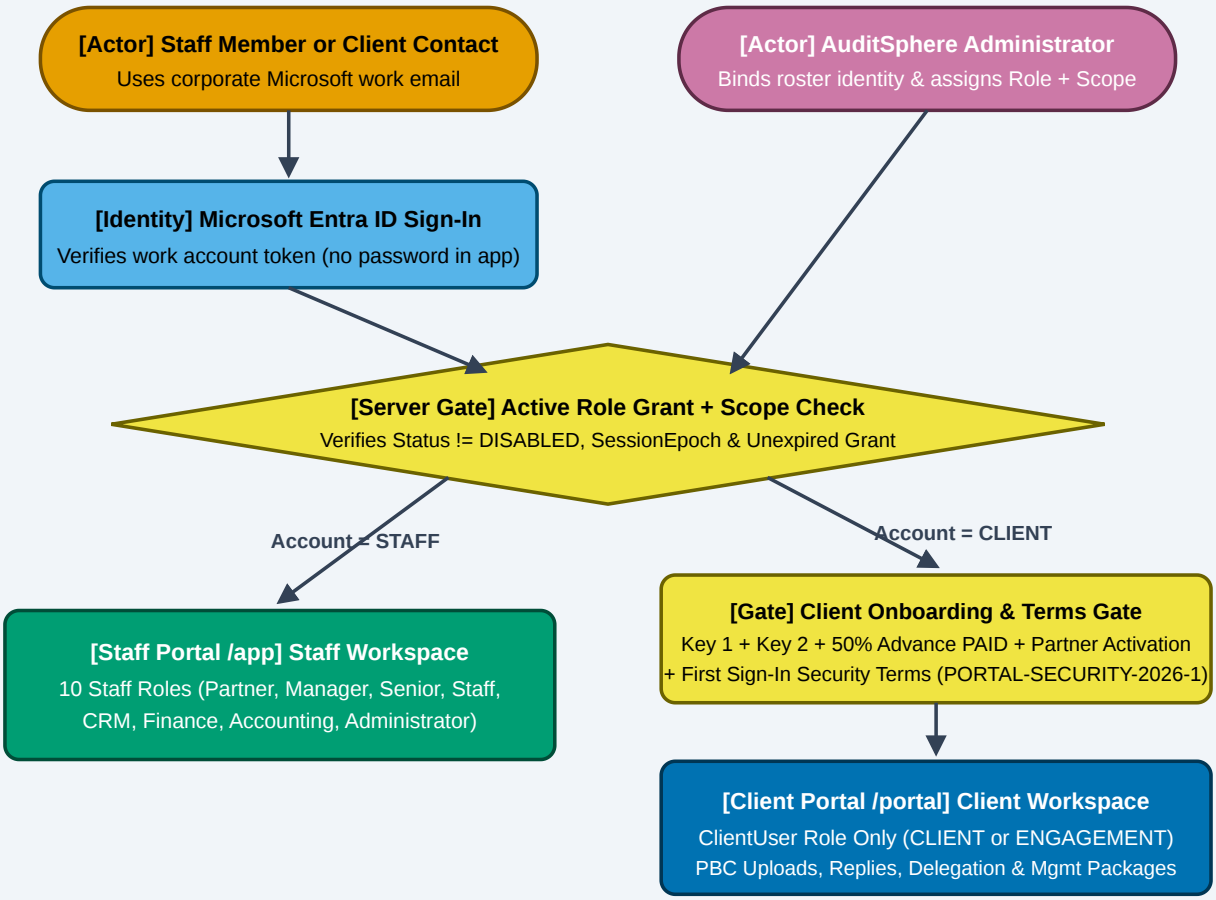


Diagram A: Microsoft sign-in verifies identity; the AuditSphere server checks the Administrator-assigned Role and Scope before opening either the Staff Workspace or the Client Portal.

3. Role plus scope

Every access grant pairs a **Role** (who the person is and what actions they can perform) with a **Scope** (where they are permitted to act):

Scope Code	Plain-English Meaning	Example	Strict Boundary (What It Never Covers)
`FIRM_WIDE`	Across your firm's eligible portfolio for that role. Required for firm administration, firm ledger books, and CRM pipeline management.	Amira holds `Partner` at `FIRM_WIDE`; Omar holds `Administrator` at `FIRM_WIDE`.	Never allowed for `ClientUser`. Does not grant other roles or cross-firm access.
`CLIENT`	One specific client company and its engagements (where the operation accepts client-level scope).	Tariq holds `Manager` on **Client: Gulf Horizon Trading LLC**.	Cannot view or act on any sibling client company or firm-wide ledger/admin screens.
`ENGAGEMENT`	One specific audit or accounting engagement. The server resolves the parent client link from stored database records.	Lina holds `Senior` on **Engagement: Gulf Horizon FY2026 Statutory Audit**.	Cannot see other engagements of the same client (such as FY2025 Audit or Tax Advisory).
`GROUP`	One corporate consolidation group via a dedicated `GroupAccessGrant`.	Youssef holds `AccountingPreparer` on **Group: Gulf Horizon Holdings Group**.	Cannot have an expiry date; forbidden for `Senior`, `RelationshipManager`, and `ClientUser`; does not open standalone subsidiary client books.

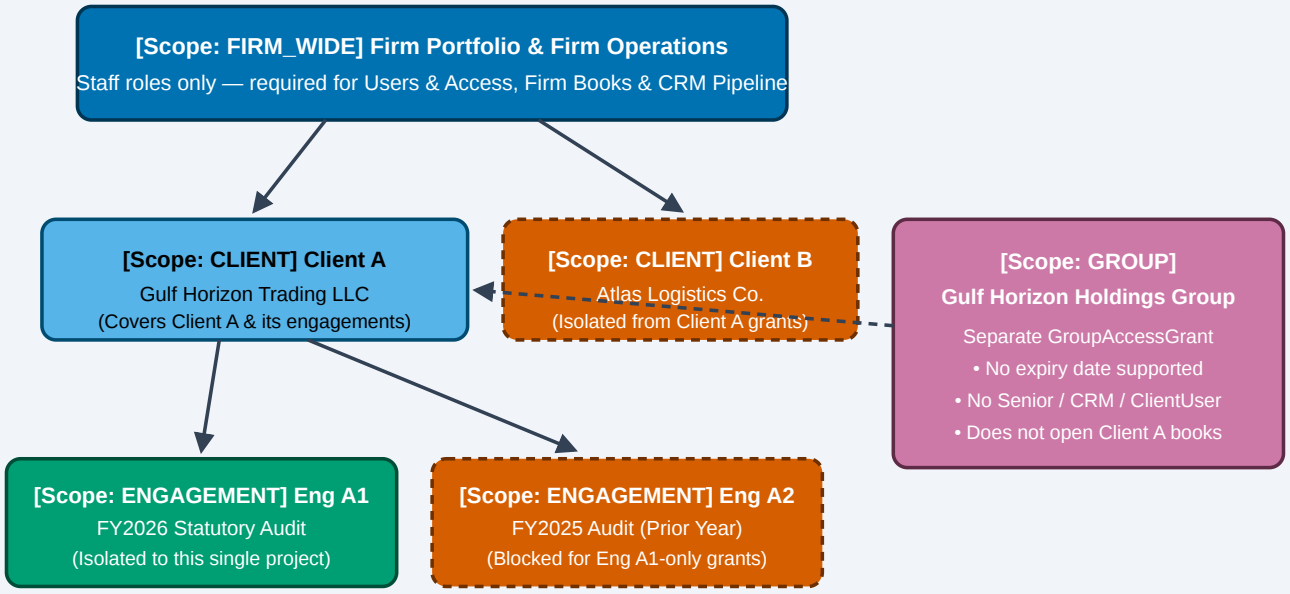


Diagram B: FIRM_WIDE, CLIENT, and ENGAGEMENT follow your client-and-project hierarchy, while GROUP is a separate consolidation grant that never opens standalone subsidiary client books.

4. Role cards (all 11 assignable roles)

Click any role card below to view its 9 standard attributes (summary & titles, daily responsibilities, what they can do, what they cannot do, decisions they own, handoffs, scope options, screens, and how access ends).

▼ **1. Partner — Code:** `Partner`

Account Type: Staff | Scopes: FIRM_WIDE, CLIENT, ENGAGEMENT, GROUP

One-line summary & typical job titles: Engagement leader and signing authority who owns Key 2 risk clearance, engagement activation, high-risk audit clearance, opinion signing, and final financial package release. *Typical titles: Engagement Partner, Audit Partner, Managing Partner, EQR Partner.*

DAILY RESPONSIBILITIES

Evaluates client acceptance & independence risk, activates engagements after commercial/advance gates clear, locks materiality/SRM, clears high-risk procedures, concurs as independent EQR Partner, approves financial packages, verifies signed LORs, and signs the audit opinion/report.

WHAT THEY CAN DO

Record Key 2 Partner risk clearance; activate engagements; approve planning, SRM & high-risk (`HIGH`) procedures; perform independent EQR concurrence; verify signed LORs; sign opinions & reports; approve/release financial packages; configure EOS provision policy, pricing rules, workflow templates & technical library.

WHAT THEY CANNOT DO / NEED SOMEONE ELSE FOR

Cannot record Key 1 client commercial acceptance; cannot activate an engagement before the 50% advance milestone is marked `PAID` by Finance; cannot review work they prepared themselves; cannot serve as EQR Partner on their own engagement; cannot manage

DECISIONS THEY OWN

Key 2 risk clearance, engagement activation, planning & SRM lock, high-risk procedure clearance, EQR concurrence (when assigned), signed LOR verification, financial package Partner release, audit opinion, report signing & archive freeze.

`Users & Access` without `Administrator`.

WHO THEY HAND OFF TO OR ARE REVIEWED BY

Receives manager-reviewed audit files and accounting packages from `Manager` and `AccountingReviewer`; peer-reviewed by an independent `Partner` when EQR applies.

SCOPE OPTIONS

`FIRM_WIDE`, `CLIENT`, `ENGAGEMENT`, `GROUP` (Engagement sign-offs also require `ENGAGEMENT_PARTNER` staffing; `GROUP` grants cannot have an expiry date).

SCREENS THEY WILL SEE

`Portfolio Overview`, `CRM & Pipeline`, `Client Directory`, `Proposals & Fees`, `Engagement Directory`, `Workflow & Tasks`, `Resource Planning`, `Client Progress`, `Accounting & R2R`, `Audit Fieldwork`, `My Time & Leave`, `Practice Analytics`, `Consolidation Groups`, `Technical Library`.

HOW ACCESS ENDS (EXPIRY OR REVOCATION)

Automatic revocation at `ExpiresAt` (`Source = "EXPIRY"`, `NewRole = "EXPIRED"`) or immediate revocation/disablement by an `Administrator` with `SessionEpoch` increment.

▼

2. Manager — Code: `Manager`

Account Type: Staff | Scopes: FIRM_WIDE, CLIENT, ENGAGEMENT, GROUP

One-line summary & typical job titles: Engagement and practice manager who plans resources, staffs engagements, reviews fieldwork and client accounting stages, and prepares files for Partner sign-off. *Typical titles: Audit Manager, Assurance Manager, Senior Audit Manager.*

DAILY RESPONSIBILITIES

Creates draft engagements, manages staffing & resource capacity, oversees workflow plans, proposes or decides conditional task exclusions, reviews Rank

WHAT THEY CAN DO

Create draft engagements; staff engagements up to Audit Manager rank; review procedures (Rank 3), review notes & confirmations; propose or independently

3 fieldwork procedures and confirmations, approves staff time entries, and reviews client accounting mappings/packages.

decide conditional task exclusions; approve time entries; prepare & review client accounting mappings, adjustments, reconciliations, financial packages & consolidation groups; curate `Technical Library`.

WHAT THEY CANNOT DO / NEED SOMEONE ELSE FOR

Cannot record Key 2 risk clearance, activate engagements, clear Partner-only (Rank 4 / `HIGH`) procedures, sign opinions/reports, or release Partner packages. Cannot review their own prepared work or decide their own conditional task exclusion proposal. Cannot access Firm Finance or User Administration.

DECISIONS THEY OWN

Staffing & resource plans, Rank 3 procedure/review-note clearance, conditional task exclusion decisions (when independent), time approval, and Manager-stage accounting review.

WHO THEY HAND OFF TO OR ARE REVIEWED BY

Reviews work from `Staff`, `Senior`, and `AccountingPreparer`; hands off reviewed files and packages to `Partner`.

SCOPE OPTIONS

`FIRM_WIDE`, `CLIENT`, `ENGAGEMENT`, `GROUP` (`GROUP` grants do not support expiry).

SCREENS THEY WILL SEE

`Portfolio Overview`, `CRM & Pipeline`, `Client Directory`, `Proposals & Fees`, `Engagement Directory`, `Workflow & Tasks`, `Resource Planning`, `Client Progress`, `Accounting & R2R`, `Audit Fieldwork`, `My Time & Leave`, `Practice Analytics`, `Consolidation Groups`, `Technical Library`.

HOW ACCESS ENDS (EXPIRY OR REVOCATION)

Automatic revocation at `ExpiresAt` or immediate manual revocation/disablement by an `Administrator` with `SessionEpoch` increment.

▼

3. Senior — Code: `Senior`

Account Type: Staff | Scopes: FIRM_WIDE, CLIENT, ENGAGEMENT (No GROUP)

One-line summary & typical job titles: Fieldwork coordinator who executes complex audit procedures, manages sampling and confirmations, handles PBC evidence intake, and performs first-level review of low/medium-risk work. *Typical titles: Senior Auditor, Audit Senior, In-Charge Accountant.*

DAILY RESPONSIBILITIES

Coordinates fieldwork execution, imports trial balances, performs substantive procedures and sampling, manages PBC requests and client uploads, and reviews Rank 2 procedures prepared by Staff.

WHAT THEY CAN DO

Prepare working papers, procedures, confirmations, finding responses & trial-balance intake; manage PBC requests; review procedures & review notes where risk band permits Rank 2 (and Senior is not preparer); log time & tasks; read `PARTNERS_AND_MANAGERS` technical library.

WHAT THEY CANNOT DO / NEED SOMEONE ELSE FOR

Cannot hold `GROUP` scope; cannot review own work or clear Rank 3/4 procedures; cannot approve accounting mappings, adjustments, or financial packages; cannot manage staffing, approve time, or access CRM, Firm Finance, or Administration.

DECISIONS THEY OWN

Rank 2 procedure and review-note clearance (when independent of preparation) and PBC evidence intake verification.

WHO THEY HAND OFF TO OR ARE REVIEWED BY

Reviews `Staff` work within Rank 2 limits; hands off fieldwork sections and findings to `Manager` and `Partner`.

SCOPE OPTIONS

`FIRM_WIDE`, `CLIENT`, `ENGAGEMENT` (`GROUP` is prohibited by server validation).

SCREENS THEY WILL SEE

`Portfolio Overview`, `Engagement Directory`, `Workflow & Tasks`, `Client Progress`, `Accounting & R2R` (TB/GL intake & read views), `Audit Fieldwork`, `My Time & Leave`, `Technical Library`.

HOW ACCESS ENDS (EXPIRY OR REVOCATION)

Automatic revocation at `ExpiresAt` or immediate manual revocation/disablement by an `Administrator` with `SessionEpoch` increment.

▼ 4. Staff — Code: `Staff`

Account Type: Staff | Scopes: FIRM_WIDE, CLIENT, ENGAGEMENT, GROUP

One-line summary & typical job titles: Core engagement team member who prepares assigned working papers, imports source trial balances, drafts adjustment journals, manages PBC items, and logs time. *Typical titles: Audit Associate, Staff Auditor, Junior Accountant.*

DAILY RESPONSIBILITIES

Executes assigned audit procedures, uploads working paper evidence, imports trial balance / GL files, drafts adjustment journals and statement layouts, responds to review notes, and logs daily time.

WHAT THEY CAN DO

Prepare assigned procedures, working papers & tasks; import TB/GL datasets; draft adjustment journals, adjustment plans, statement layouts & package seal preparation; manage PBC staff inbox; respond to review notes; log time; read `ALL_STAFF` technical library.

WHAT THEY CANNOT DO / NEED SOMEONE ELSE FOR

Cannot review or approve any procedure, review note, mapping, journal, reconciliation, or package (Rank 1 has zero review authority); cannot prepare FSLI mapping drafts requiring `AccountingPreparer`; cannot access CRM, Firm Finance, or Administration.

DECISIONS THEY OWN

None — strictly a preparation role; all outputs require independent review.

WHO THEY HAND OFF TO OR ARE REVIEWED BY

SCOPE OPTIONS

Hands off prepared working papers, procedures, and draft adjustments to `Senior`, `Manager`, or `AccountingReviewer`.

`FIRM_WIDE`, `CLIENT`, `ENGAGEMENT`, `GROUP` (`GROUP` grants do not support expiry).

SCREENS THEY WILL SEE

`Portfolio Overview`, `Engagement Directory`, `Workflow & Tasks`, `Client Progress`, `Accounting & R2R` (preparation views), `Audit Fieldwork`, `My Time & Leave`, `Technical Library`.

HOW ACCESS ENDS (EXPIRY OR REVOCATION)

Automatic revocation at `ExpiresAt` or immediate manual revocation/disablement by an `Administrator` with `SessionEpoch` increment.

▼ 5. Relationship Manager — Code: `RelationshipManager`

Account Type: Staff | Scopes: FIRM_WIDE, CLIENT, ENGAGEMENT (No GROUP)

One-line summary & typical job titles: Commercial and client-relationship lead who manages leads, client profiles, proposals, fee agreements, Key 1 acceptance evidence, and draft engagement setup. *Typical titles: Relationship Manager, Business Development Manager, Client Onboarding Lead.*

DAILY RESPONSIBILITIES

Qualifies CRM leads, converts leads to clients, maintains client contacts, drafts proposals and quotations, generates fee agreements, records Key 1 client acceptance, and creates draft engagements.

WHAT THEY CAN DO

Manage CRM leads, opportunities, client profiles & contacts; prepare proposals/quotations & fee agreements; record Key 1 client commercial acceptance of the exact proposal revision; create draft engagements; view onboarding readiness.

WHAT THEY CANNOT DO / NEED SOMEONE ELSE FOR

Cannot record Key 2 Partner risk clearance or activate engagements (Partner only); cannot configure

DECISIONS THEY OWN

Lead qualification, proposal preparation, and recording Key 1 client commercial acceptance evidence.

commercial pricing rules (Partner/Admin only); cannot hold `GROUP` scope; cannot access audit fieldwork, client accounting, firm billing/ledger, or user administration.

WHO THEY HAND OFF TO OR ARE REVIEWED BY

Hands off accepted proposals and draft engagements to `Partner` (for Key 2 risk clearance & activation) and `FinanceManager` (for 50% advance billing).

SCOPE OPTIONS

`FIRM_WIDE`, `CLIENT`, `ENGAGEMENT` (No `GROUP` scope; CRM pipeline & fee-agreement queries require `FIRM_WIDE`).

SCREENS THEY WILL SEE

`Portfolio Overview`, `CRM & Pipeline`, `Client Directory`, `Proposals & Fees`, `Engagement Directory` (drafts & onboarding), `My Time & Leave`, `Technical Library`.

HOW ACCESS ENDS (EXPIRY OR REVOCATION)

Automatic revocation at `ExpiresAt` or immediate manual revocation/disablement by an `Administrator` with `SessionEpoch` increment.

▼

6. Finance Manager — Code: `FinanceManager`

Account Type: Staff | Scopes: FIRM_WIDE, CLIENT, ENGAGEMENT, GROUP

One-line summary & typical job titles: Firm finance preparer who manages client billing accounts, drafts invoices and credit notes, records receipts and advance milestone payments, and prepares firm general ledger journals. *Typical titles: Finance Manager, Practice Accountant, Billing Manager.*

DAILY RESPONSIBILITIES

Sets up billing accounts, drafts milestone/advance invoices, issues credit notes, records and allocates client receipts (including the 50% advance gate), submits payment-terms or

WHAT THEY CAN DO

Create billing accounts, draft invoices & credit notes, record/allocate receipts, request payment-terms changes or receipt allocation reversals, and prepare firm general ledger journals & expenses (firm ledger requires `FIRM_WIDE`).

allocation-reversal requests, and prepares firm ledger journals.

WHAT THEY CANNOT DO / NEED SOMEONE ELSE FOR

Cannot approve invoices, firm ledger journals, payment-terms changes, or allocation reversals (requires an independent `FinanceReviewer`); cannot touch client accounting books (R2R) or audit working papers.

DECISIONS THEY OWN

Preparation of firm billing records, receipt recording/allocation, and submission of firm ledger journals and billing change requests.

WHO THEY HAND OFF TO OR ARE REVIEWED BY

Submits invoices, journals, payment-terms requests, and allocation reversals to an independent `FinanceReviewer`.

SCOPE OPTIONS

`FIRM_WIDE`, `CLIENT`, `ENGAGEMENT`, `GROUP` (Firm books & ledger require `FIRM_WIDE`; billing accepts `CLIENT` or `FIRM_WIDE`).

SCREENS THEY WILL SEE

`Portfolio Overview`, `Firm Billing`, `Firm Books`, `Practice Analytics` (finance views), `My Time & Leave`, `Technical Library`.

HOW ACCESS ENDS (EXPIRY OR REVOCATION)

Automatic revocation at `ExpiresAt` or immediate manual revocation/disablement by an `Administrator` with `SessionEpoch` increment.

▼ 7. Finance Reviewer — Code: `FinanceReviewer`

Account Type: Staff | Scopes: FIRM_WIDE, CLIENT, ENGAGEMENT, GROUP

One-line summary & typical job titles: Independent firm finance checker who reviews and approves firm invoices, general ledger journals, payment-terms changes, receipt allocation reversals, and period controls. *Typical titles: Financial Controller, Finance Reviewer, Head of Finance.*

DAILY RESPONSIBILITIES

WHAT THEY CAN DO

Independently reviews and approves/rejects draft client invoices, firm general ledger journals, payment-terms requests, receipt allocation reversals, firm expenses, and accounting period locks.

Approve/reject firm invoices, ledger journals, payment-terms changes, allocation reversals & expenses; manage firm ledger period controls (`FIRM_WIDE`); also permitted to create invoices and record/allocate receipts in `BillingService`.

WHAT THEY CANNOT DO / NEED SOMEONE ELSE FOR

STRICT MAKER-CHECKER:

Cannot approve any invoice, journal, payment-terms request, or reversal that they created/requested themselves—even if granted both finance roles. Cannot prepare firm ledger journals without `FinanceManager`. No client-accounting or audit access.

DECISIONS THEY OWN

Independent maker-checker approval of firm invoices, firm ledger postings, payment-terms changes, allocation reversals, and period locks.

WHO THEY HAND OFF TO OR ARE REVIEWED BY

Reviews submissions from `FinanceManager`; paid advance milestones unlock `Partner` engagement activation.

SCOPE OPTIONS

`FIRM_WIDE`, `CLIENT`, `ENGAGEMENT`, `GROUP` (`FIRM_WIDE` required for firm ledger approvals & period controls).

SCREENS THEY WILL SEE

`Portfolio Overview`, `Firm Billing`, `Firm Books`, `Practice Analytics` (finance views), `My Time & Leave`, `Technical Library`.

HOW ACCESS ENDS (EXPIRY OR REVOCATION)

Automatic revocation at `ExpiresAt` or immediate manual revocation/disablement by an `Administrator` with `SessionEpoch` increment.

▼

8. Accounting Preparer — Code: `AccountingPreparer`

Account Type: Staff | Scopes: FIRM_WIDE, CLIENT, ENGAGEMENT, GROUP

One-line summary & typical job titles: Client accounting and Record-to-Report (R2R) specialist who prepares trial balance mappings, adjustments, reconciliations, specialist schedules, financial statements, and group consolidations. *Typical titles: Client Accountant, R2R Specialist, Consolidation Accountant.*

DAILY RESPONSIBILITIES

Imports client trial balances/GLs, maintains charts of accounts, drafts FSLI mappings, prepares client adjustment journals, reconciliations, and valuation schedules, builds financial statements, and prepares group consolidation runs.

WHAT THEY CAN DO

Prepare client accounting datasets, COA, FSLI mapping drafts, adjustment journals/plans, reconciliations, specialist schedules, financial statement sets/packages, and group consolidation eliminations/translations.

WHAT THEY CANNOT DO / NEED SOMEONE ELSE FOR

Cannot review or approve accounting sources, mappings, adjustments, reconciliations, financial packages, or consolidation runs (requires `AccountingReviewer`, `Manager`, or `Partner`); cannot access Firm Finance or audit procedure sign-offs.

DECISIONS THEY OWN

Preparation and submission of client accounting schedules, FSLI mappings, financial statements, and consolidation runs.

WHO THEY HAND OFF TO OR ARE REVIEWED BY

Hands off prepared mappings, adjustments, reconciliations, packages, and consolidations to an independent `AccountingReviewer` or `Manager`.

SCOPE OPTIONS

`FIRM_WIDE`, `CLIENT`, `ENGAGEMENT`, `GROUP` (`GROUP` creates a `GroupAccessGrant` with no expiry date).

SCREENS THEY WILL SEE

`Portfolio Overview`, `Engagement Directory`, `Accounting & R2R` (all 5 sub-workspaces), `Consolidation Groups`, `My Time & Leave`, `Technical Library`.

HOW ACCESS ENDS (EXPIRY OR REVOCATION)

Automatic revocation at `ExpiresAt` (except `GROUP`) or immediate manual revocation/disablement by an

`Administrator` with `SessionEpoch` increment.

▼

9. Accounting Reviewer — Code: `AccountingReviewer`

Account Type: Staff | Scopes: FIRM_WIDE, CLIENT, ENGAGEMENT, GROUP

One-line summary & typical job titles: Independent client accounting and consolidation reviewer who approves trial balance mappings, adjustments, reconciliations, financial package accounting stages, and group consolidations. *Typical titles: Accounting Review Manager, Technical Accounting Reviewer, R2R Manager.*

DAILY RESPONSIBILITIES

Verifies client trial balance sources, approves FSLI mappings, reviews and posts client adjustment journals, signs off reconciliations and specialist schedules, completes the accounting review stage on financial packages, and reviews group consolidations.

WHAT THEY CAN DO

Independently review and approve client accounting sources, FSLI mappings, adjustment journals, reconciliations, financial package accounting stage, and group consolidations; also accepted in preparation guards where not self-reviewing.

WHAT THEY CANNOT DO / NEED SOMEONE ELSE FOR

STRICT SELF-REVIEW PROHIBITION:

Cannot approve any mapping, adjustment, reconciliation, package, or consolidation they prepared themselves. Cannot perform final Partner package release, Partner risk clearance, audit opinion sign-off, or Firm Finance approvals.

DECISIONS THEY OWN

Independent accounting review approval for client TB sources, mappings, adjustments, reconciliations, financial package accounting review, and group consolidation review.

WHO THEY HAND OFF TO OR ARE REVIEWED BY

Reviews work from `AccountingPreparer` and `Staff`;

SCOPE OPTIONS

`FIRM_WIDE`, `CLIENT`, `ENGAGEMENT`, `GROUP` (`GROUP` grants do not support expiry).

hands off reviewed financial packages to `Partner` for final Partner approval and release.

SCREENS THEY WILL SEE

`Portfolio Overview`, `Engagement Directory`, `Accounting & R2R` (all 5 sub-workspaces), `Consolidation Groups`, `My Time & Leave`, `Technical Library`.

HOW ACCESS ENDS (EXPIRY OR REVOCATION)

Automatic revocation at `ExpiresAt` (except `GROUP`) or immediate manual revocation/disablement by an `Administrator` with `SessionEpoch` increment.

▼

10. Administrator — Code: `Administrator`

Account Type: Staff | Scopes: FIRM_WIDE, CLIENT, ENGAGEMENT, GROUP

One-line summary & typical job titles: Platform and access administrator who binds user identities, assigns and revokes role grants, maintains firm configuration, and holds audited read-only oversight on 13 registered finance and consolidation views without holding Partner or Finance authority. *Typical titles: IT & Access Administrator, Practice Operations Administrator.*

DAILY RESPONSIBILITIES

Binds staff and client emails to roster identities, assigns/revokes role grants, copies invitation links, configures firm settings and workflow templates, manages optional Microsoft 365 capabilities, and monitors immutable audit logs.

WHAT THEY CAN DO

Manage `Users & Access` (search, bind roster identity, assign/revoke roles, disable/enable users, copy invitation links at `FIRM_WIDE`); configure firm settings, pricing rules, workflow templates & technical library; propose/decide conditional task exclusions; view 13 registered read-only oversight queries in Firm Finance & Group Consolidation (logging an immutable `AdministratorOversightAccessEvent`).

WHAT THEY CANNOT DO / NEED SOMEONE ELSE FOR

"ADMINISTRATOR ACCESS DOES NOT CONFER PARTNER, FINANCEMANAGER, OR FINANCEREVIEWER AUTHORITY":

Cannot clear Partner risk gates, activate engagements, sign audit opinions/reports, approve financial packages, or create/approve firm invoices or journals. Oversight is strictly read-only.

DECISIONS THEY OWN

Identity roster binding, role/scope grant assignment and revocation, account enablement/disablement, firm configuration, and conditional task exclusion decisions (when not proposer).

WHO THEY HAND OFF TO OR ARE REVIEWED BY

Executes access requests approved by Partners, Managers, or client leads; all actions are logged in append-only `RoleGrantAuditEvents` and `AdministratorOversightAccessEvents`.

SCOPE OPTIONS

`FIRM_WIDE`, `CLIENT`, `ENGAGEMENT`, `GROUP` (`FIRM_WIDE` required for `Users & Access`, `Firm Settings`, `Microsoft 365`, and read-only oversight).

SCREENS THEY WILL SEE

`Users & Access`, `Firm Settings`, `Microsoft 365`, `Oversight History`, `Workflow & Tasks`, `Technical Library`, plus `Firm Billing`, `Firm Books` & `Consolidation Groups` in `Read-only — Administrator oversight` mode.

HOW ACCESS ENDS (EXPIRY OR REVOCATION)

Automatic revocation at `ExpiresAt` or immediate revocation/disablement by another `Administrator` with `SessionEpoch` increment.

▼

11. Client User — Code: `ClientUser`

Account Type: Client | Scopes: CLIENT, ENGAGEMENT Only

One-line summary & typical job titles: External client representative who uses the isolated Client Portal (`/portal`) to upload requested PBC audit documents, reply to queries, respond

to management journals/packages, and delegate PBC items. *Typical titles: Client Finance Director, Chief Accountant, Financial Controller.*

DAILY RESPONSIBILITIES

Reviews open PBC document requests, uploads supporting evidence files, answers audit team messages, reviews and responds to shared management adjustment journals and financial packages, and delegates PBC items to client colleagues.

WHAT THEY CAN DO

Accept first-sign-in security terms (`PORTAL-SECURITY-2026-1`); view assigned PBC requests, upload evidence & post replies; record management responses on shared journals & financial packages; delegate a PBC request to another active `ClientUser` of the same client (when primary contact & request owner).

WHAT THEY CANNOT DO / NEED SOMEONE ELSE FOR

Never allowed `FIRM_WIDE` or `GROUP` scope; blocked from `/portal` until all 4 onboarding gates clear (Key 1 acceptance + Key 2 Partner risk clearance + 50% advance `PAID` + Partner activation); denied all internal `/app` screens and working papers.

DECISIONS THEY OWN

First-sign-in security acknowledgment, PBC evidence uploads, PBC request delegation (when primary contact/owner), and management responses on shared journals/packages.

WHO THEY HAND OFF TO OR ARE REVIEWED BY

Uploads PBC evidence and management responses for verification by `Staff` , `Senior` , `Manager` , `AccountingReviewer` , and `Partner` .

SCOPE OPTIONS

`CLIENT` , `ENGAGEMENT` only (**NEVER** `FIRM_WIDE` or `GROUP`).

SCREENS THEY WILL SEE

`Client Portal Home` (`/portal`), `Information Request (PBC) Detail` (`/portal/requests/:id`), `Management Package Review`

HOW ACCESS ENDS (EXPIRY OR REVOCATION)

Automatic revocation at `ExpiresAt` or immediate revocation/disablement by an `Administrator` with `SessionEpoch` increment.

(`/portal/accounting/packages/:id`), `Management Journal Review` (`/portal/accounting/journals/:id`).

5. Who does what across the engagement lifecycle

> **Crucial Rule — Lifecycle State Is Derived from Evidence, Not Set by Tasks:** Nobody can manually advance an engagement phase by checking off a to-do task. AuditSphere derives the 7 display phases automatically from verified domain evidence (accepted proposal revision, unconditional Partner risk clearance, paid 50% advance milestone, approved planning & SRM lock, signed-off procedures, verified LOR, signed opinion, and sealed archive manifest).

Display Phase	`RelationshipManager`	`Finance Manager` & `Finance Reviewer`	`Partner`	`Manager`	`Senior` & `Staff`	`Accounti Preparer` `Accounti Reviewer`
1 Onboarding	Prepares proposal; records Key 1 acceptance; creates draft engagement	Issues 50% advance invoice, approves (`Finance Reviewer`) & allocates receipt (`PAID`)	Records Key 2 unconditional risk clearance; activates engagement	Sets up initial staffing plan	Waits for activation & staffing	Waits for activation
2 Planning	Views onboarding status	Monitors milestone billing	Locks materiality/SRM & approves planning completion	Builds workflow plan, resource allocations & risk owners	Prepares preliminary analytics & PBC request lists	Imports opening TB/GL & s up Chart o Accounts
3 Fieldwork	—	Issues progress billing (Maker-Checker)	Oversees significant risks	Manages conditional task exclusions & progress	Executes 20-section/165-procedure programme; `Senior`	`Accounti Preparer` drafts mappings, adjustmen

Display Phase	`RelationshipManager`	`Finance Manager` & `Finance Reviewer`	`Partner`	`Manager`	`Senior` & `Staff`	`Accounti Preparer` `Accounti Reviewer`
					reviews Rank 2	reconciliati & stateme
4 Manager review	—	—	Reviews escalated high-risk findings	Reviews Rank 3 procedures, review notes & confirmations	Responds to and clears review notes	`Accounti Reviewer` approves mappings, adjustmen reconciliati & package stage
5 Partner sign-off	—	—	Clears High-Risk procedures, verifies signed LOR, approves package & opinion (+ independent EQR)	Hands off reviewed completion file to Partner	Ensures all procedure evidence snapshots are sealed	Resolves f Partner accounting queries
6 Report and delivery	—	Issues final invoice & allocates receipt	Signs final audit report (X.509 PDF) & authorizes package release	Coordinates report assembly & delivery	—	Generates final seale financial statement package
7 Archive and close	—	Closes billing milestones	Authorizes archive freeze (append-only SHA-256 manifest)	Verifies retention completeness	Read-only on frozen file	Read-only sealed datasets

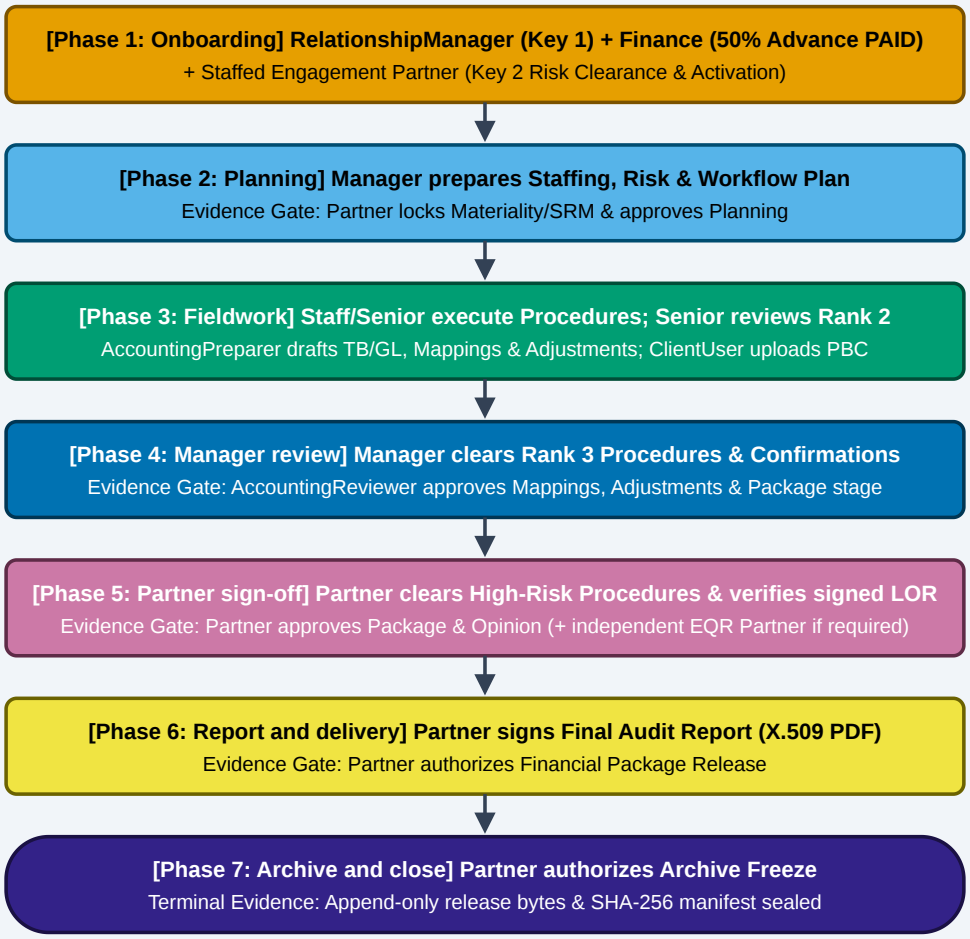


Diagram C: Each of the 7 lifecycle phases advances only when the server verifies the underlying domain evidence—never simply because a task checkbox was ticked.

6. Approvals and separation of duties

- **Dual-Key Acceptance + Paid 50% Advance (`ADR-0003` & `ADR-0012`):** Engagement activation and Client Portal access require (1) **Key 1** client commercial acceptance of the exact proposal revision, (2) **Key 2** unconditional risk clearance by the staffed `ENGAGEMENT_PARTNER`, and (3) the 50% `ADVANCE` billing milestone marked `PAID`.
- **Preparer Is Never Reviewer (Maker-Checker):** Across audit procedures, conditional task exclusions, client accounting mappings/adjustments/reconciliations/packages/consolidations, and firm invoices/ledger journals, the server checks `PreparedByUserId != ReviewerUserId`. Assigning two roles to one user never bypasses the two-person rule.
- **Partner-Only Authority & Independent EQR:** Only a `Partner` can clear Key 2 risk, activate engagements, approve high-risk procedures, verify signed LORs, sign opinions/reports, or release financial packages. When EQR applies, the EQR Partner must be a different `Partner` from the Engagement Partner.
- **Administrator Is Not Partner:** `Administrator` access provides user management and 13 audited read-only oversight views, but **never** confers `Partner`, `FinanceManager`, or `FinanceReviewer` authority.

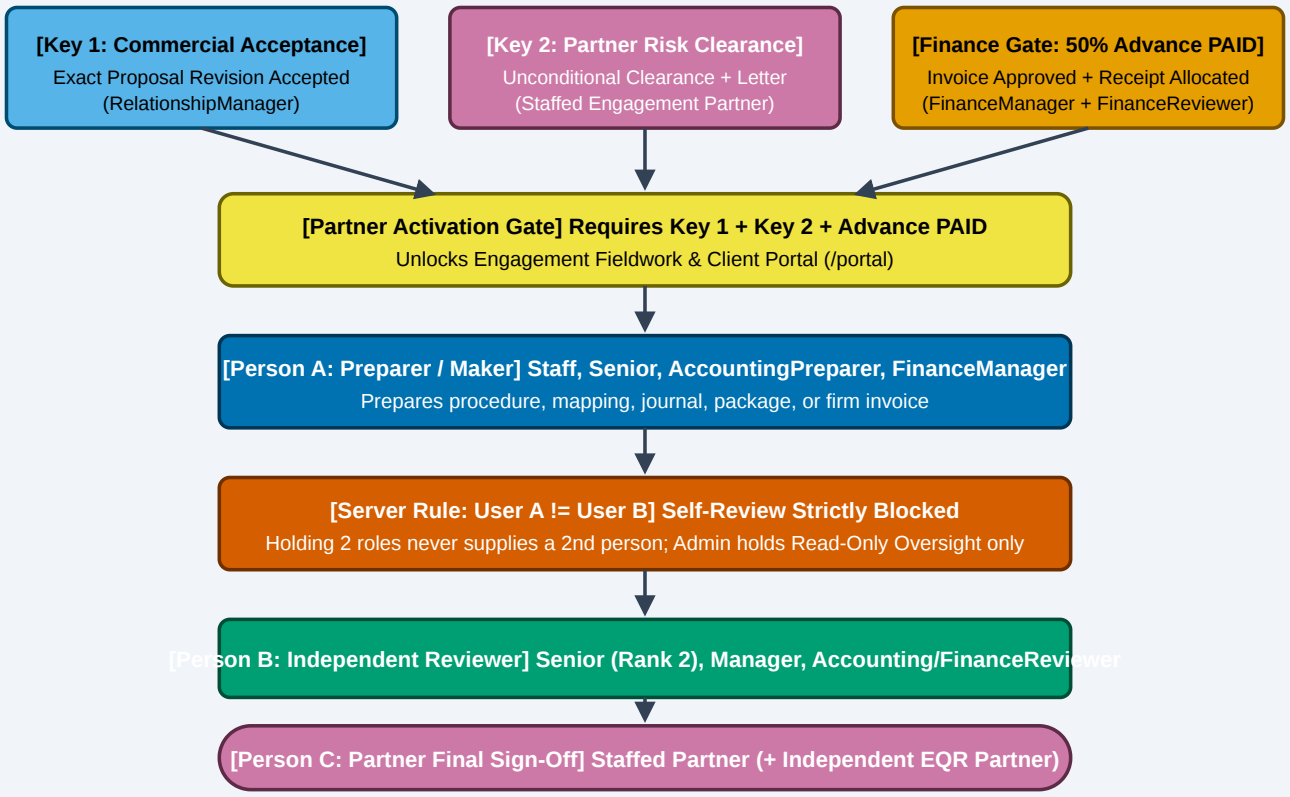


Diagram D: Activation requires Key 1, Key 2, and a paid 50% advance; every subsequent workflow enforces strict two-person maker-checker independence (User A != User B).

7. Role vs capability matrix

Server-enforced capabilities across all **10 AuditSphere modules** and **11 assignable roles**.

Legend: Full | Requires another person's approval | View-only | None

Module Name	`Partner`	`Manager`	`Senior`	`Staff`	`RelationshipManager`
1. Practice and commercial	Requires another person's approval Key 2 clearance, activation & pricing rules	Requires another person's approval Draft engagements; Partner clears Key 2	View-only Reads scoped client/engagement	View-only Reads scoped summary	Requires another person's approval CRM, proposals & Key 1; Partner clears Key 2
2. Workflow and tasks	Requires another person's approval Plans & exclusions (2-person rule)	Requires another person's approval Plans & exclusions (2-person rule)	Full Executes assigned workflow tasks	Full Executes assigned workflow tasks	None
3. Client accounting and reporting	Requires another person's approval Final Partner package release & EOS	Requires another person's approval Reviews mappings/packages; Partner releases	Requires another person's approval TB/GL intake; no mapping/package approval	Requires another person's approval TB/GL intake & draft adjustments	None

Module Name	Partner	Manager	Senior	Staff	RelationshipManager
4. Audit and records	**Requires another person's approval** High-risk, LOR, opinion, report & EQR	**Requires another person's approval** Rank 3 review & confirmations	**Requires another person's approval** Fieldwork, PBC & Rank 2 review	**Requires another person's approval** Prepares workpapers & procedures	None
5. Firm finance	**View-only** Revenue analytics & EOS policy	None	None	None	None
6. People and time	**Full** Staffing, capacity & time approval	**Full** Staffing (up to Manager) & time approval	**Requires another person's approval** Logs own time & leave	**Requires another person's approval** Logs own time & leave	**Requi anothe perso appro** Logs o time & leave
7. Group consolidation	**Requires another person's approval** Approves & releases consolidation	**Requires another person's approval** Manages & reviews consolidation	None	**View-only** Read context only	None
8. Client portal	None	None	None	None	None

Module Name	`Partner`	`Manager`	`Senior`	`Staff`	`RelationshipManager`
9. Administration	View-only Pricing/templates co-owner; no Users & Access	None	None	None	None
10. Knowledge library	Full Curates & reads all tiers	Full Curates & reads all tiers	View-only Reads Partners/Managers & All Staff	View-only Reads All Staff tier	View-only Reads All Staff tier

8. Which role should this person have?

Follow these 5 questions from top to bottom to pick the right role for each person:

1. **Q1: Do they work for the external client company?** → Yes: `ClientUser` (`CLIENT` or `ENGAGEMENT`). No: go to Q2.
2. **Q2: Do they run platform administration, commercial CRM, or the firm's own internal billing/ledger?** → User access & settings: `Administrator` | Leads & proposals: `RelationshipManager` | Preparing firm invoices/ledger: `FinanceManager` | Approving firm invoices/ledger: `FinanceReviewer`. Otherwise go to Q3.
3. **Q3: Do they focus strictly on client accounting (R2R) or Group Consolidation without performing audit fieldwork?** → Preparing mappings, adjustments, statements, or consolidations: `AccountingPreparer` | Independently reviewing/approving them: `AccountingReviewer`. Otherwise go to Q4.
4. **Q4: Do they lead engagements, manage staffing, or sign off reviews?** → Signing opinions, Key 2 risk clearance, activation & EQR: `Partner` | Staffing, planning & Rank 3 review: `Manager`. Otherwise go to Q5.
5. **Q5: Do they coordinate fieldwork and perform Rank 2 review, or prepare assigned workpapers?** → Fieldwork lead & Rank 2 review: `Senior` | Preparing assigned workpapers & TB intake: `Staff`.

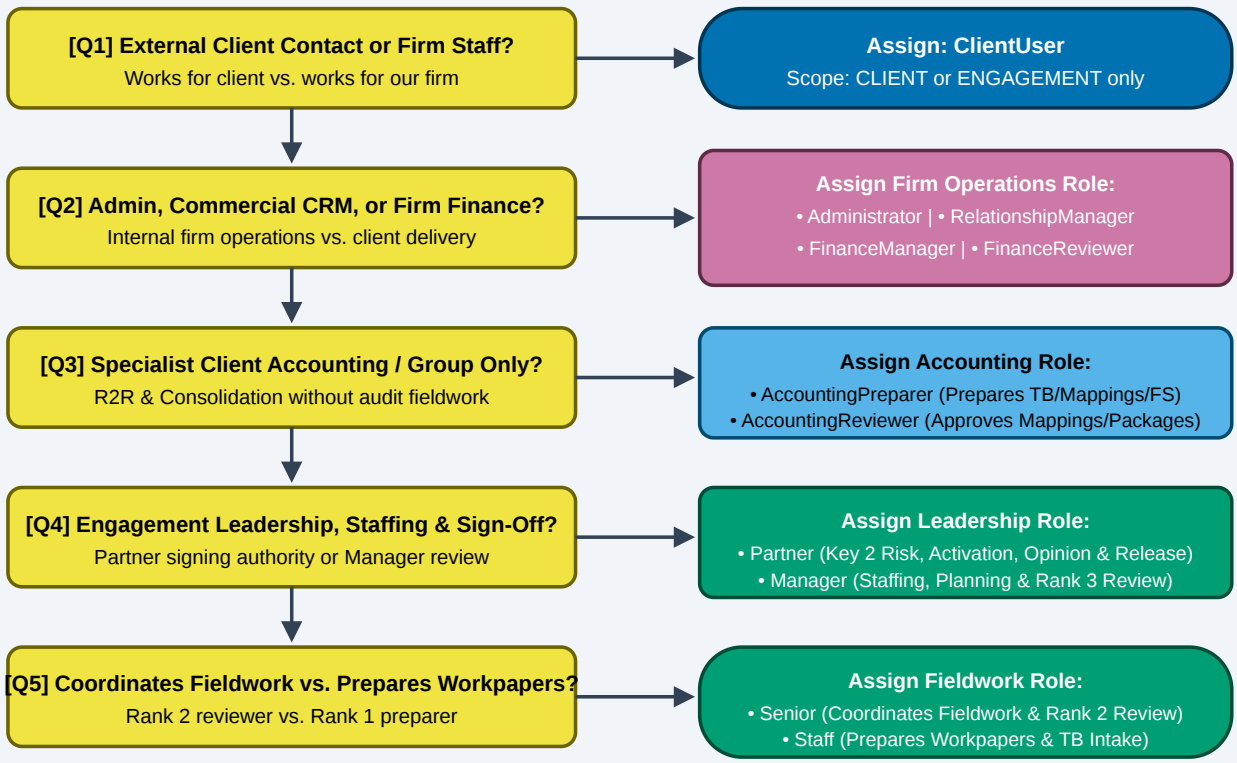


Diagram E: Follow questions Q1 through Q5 from top to bottom to identify the exact role code for each person on your list.

9. How to fill in the request form

Complete the 9 columns below (matching `auditsphere-security-template-role-assignment-request.csv`). Key rules verified from server code:

- **Exact Microsoft Sign-In Email:** Provide the exact email address (UPN) used for Microsoft Entra ID sign-in. Server validation (`RoleAdministrationService.EmailLike`) requires a single `@` symbol, no spaces, and max 320 characters. *Policy note (`TO CONFIRM`): Whether personal email domains (e.g., `@gmail.com`) or shared mailboxes (e.g., `accounts@example.com`) are prohibited by firm policy is marked `TO CONFIRM` in Appendix B.*
- **Start Date:** Access starts immediately when approved by the Administrator (future-dated `EffectiveFrom` > 1 minute ahead is rejected by the server).
- **Expiry (if temporary):** Optional UTC date/time (must be at least 5 minutes in the future). Leave blank for `GROUP` grants (expiry is not supported on `GroupAccessGrant`).

Full name	Work email (the exact account used for Microsoft sign-in)	Staff or Client	Role requested	Scope (Firm-wide / which Client / which Engagement / which Group)	Start date	Expiry (if temporary)	Approved by	N
Amira Al-Mansoor	`amira.almansoor@example.com`	Staff	`Partner`	Firm-wide	2026-11-01	—	`managing.partner@example.com`	E P s a k c
Tariq Haddad	`tariq.haddad@example.com`	Staff	`Manager`	Client: Gulf Horizon Trading LLC (CLI-2026-014)	2026-11-01	—	`amira.almansoor@example.com`	A M o F s a a r

Full name	Work email (the exact account used for Microsoft sign-in)	Staff or Client	Role requested	Scope (Firm-wide / which Client / which Engagement / which Group)	Start date	Expiry (if temporary)	Approved by	N
Lina Khoury	`lina.khoury@example.com`	Staff	`Senior`	Engagement: Gulf Horizon FY2026 Statutory Audit (ENG-2026-042)	2026-11-01	2027-03-31T18:00:00Z	`tariq.haddad@example.com`	F le C d
Rami Saleh	`rami.saleh@example.com`	Staff	`Staff`	Engagement: Gulf Horizon FY2026 Statutory Audit (ENG-2026-042)	2026-11-01	2027-02-28T18:00:00Z	`tariq.haddad@example.com`	A c re w p
Nadia Farouk	`nadia.farouk@example.com`	Staff	`RelationshipManager`	Firm-wide	2026-11-01	—	`amira.almansoor@example.com`	C p p p
Karim Mansour	`karim.mansour@example.com`	Staff	`FinanceManager`	Firm-wide	2026-11-01	—	`amira.almansoor@example.com`	F p a le jo
Salma Darwish	`salma.darwish@example.com`	Staff	`FinanceReviewer`	Firm-wide	2026-11-01	—	`amira.almansoor@example.com`	In n c re fi a
Youssef Nassar	`youssef.nassar@`	Staff	`AccountingPrepa`	Group: Gulf Horizon	2026-11-01	—	`tariq.haddad@ex`	G c

Full name	Work email (the exact account used for Microsoft sign-in)	Staff or Client	Role requested	Scope (Firm-wide / which Client / which Engagement / which Group)	Start date	Expiry (if temporary)	Approved by	N
	`example.com`		`rer`	Holdings Group (GRP-2026-003)			`ample.com`	p (d s e
Huda Zaki	`huda.zaki@example.com`	Staff	`AccountingReviewer`	Client: Gulf Horizon Trading LLC (CLI-2026-014)	2026-11-01	—	`tariq.haddad@example.com`	In re tr n a p
Omar Barakat	`omar.barakat@example.com`	Staff	`Administrator`	Firm-wide	2026-11-01	—	`managing.partner@example.com`	U A a a re o
Layla Nasser	`layla.nasser@example.com`	Client	`ClientUser`	Engagement: Gulf Horizon FY2026 Statutory Audit (ENG-2026-042)	2026-11-01	2027-04-30T18:00:00Z	`amira.almansoor@example.com`	C F – c F a re

10. What happens after you reply

1. **Request received:** Your Partner or Administrator checks role/scope alignment and confirms maker-checker pairs.
2. **Administrator verifies identity:** Searches `Users & Access` to check whether the user already exists.
3. **Identity bound or invited:** Uses `Bind a roster identity` to pre-register the user's exact Microsoft sign-in email, display name, and account type (`STAFF` or `CLIENT`).
4. **Role and scope assigned:** Saves the grant in `Assign role and scope`, writing an immutable `RoleGrantAuditEvent` and generating a copyable invitation link.
5. **First sign-in:** The user signs in with their Microsoft work account (and if `ClientUser`, accepts security terms `PORTAL-SECURITY-2026-1` once the 4 onboarding gates are met).
6. **Confirmation:** The Administrator verifies the active grant and confirms completion back to you. *(Note: Administrator turnaround SLA and invitation link TTL are marked `TO CONFIRM` in Appendix B.)*

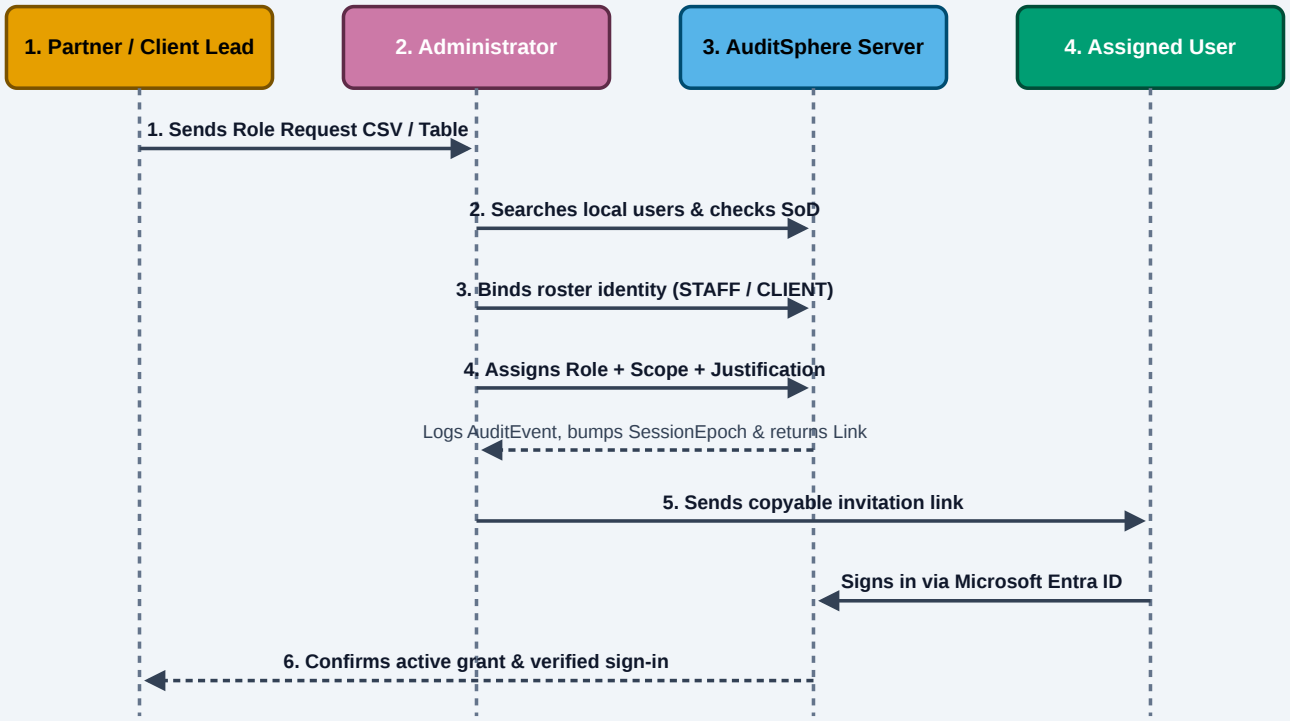


Diagram F: Six-step onboarding sequence from your email request through Administrator roster binding, grant assignment, and the user's first Microsoft sign-in.

11. Changing or removing access

- **When someone leaves or rotates off an engagement:** Email your Administrator with the person's name, work email, whether to **revoke a single role/scope grant** or **disable their entire account**, and the reason/approver.
- **Automatic Expiry (`RoleGrantExpiry`):** When `ExpiresAt` passes on a `FIRM_WIDE`, `CLIENT`, or `ENGAGEMENT` grant, the server automatically marks it revoked with `Source = "EXPIRY"` and `NewRole = "EXPIRED"` during session evaluation.
- **Immediate Session Invalidation (`SessionEpoch`):** Every grant change, expiry, revocation, or account disablement increments `AppUser.SessionEpoch`, immediately invalidating any open browser session on the next request.
- **Immutable Audit History (`RoleGrantAuditEvent`):** Revoking access never deletes past working paper sign-offs or audit history; all grant changes remain permanently recorded in `RoleGrantAuditEvents`.

12. Frequently Asked Questions (FAQ) and Glossary

Frequently Asked Questions

1. **Can one person hold multiple roles?** Yes, across the same or different scopes—but holding two roles never permits self-review.
2. **Does `Administrator` include `Partner` or `FinanceReviewer` authority?** No. Administrator access never confers Partner, FinanceManager, or FinanceReviewer authority.
3. **Why is the Client Portal locked right after granting `ClientUser`?** It opens only after Key 1 acceptance, Key 2 Partner risk clearance, the 50% advance milestone marked `PAID`, and Partner activation.
4. **Can a `ClientUser` delegate a PBC request?** Yes—if they are the request owner and the client's primary contact, they can delegate a PBC request to another active `ClientUser` of the same client.
5. **What if a commercial proposal is revised after Key 1 acceptance?** Key 1 is bound to the exact proposal revision; a new revision requires re-acceptance.
6. **Can a `GROUP` grant have an expiry date?** No; `RoleAssignmentService` blocks `ExpiresAt` on `GROUP` grants.
7. **Can we schedule a future start date for a grant?** No; `EffectiveFrom` more than 1 minute in the future is rejected by the server.
8. **Does `CLIENT` scope grant access to a parent consolidation `GROUP`?** No; group consolidation requires a separate `GROUP` grant (or `FIRM_WIDE` where accepted).
9. **How do Role Grants relate to Engagement Staffing Ranks?** Security Role Grants open routes/capabilities; Engagement Staffing (`ENGAGEMENT_PARTNER` rank 4 down to `STAFF_ASSOCIATE` rank 1) governs engagement procedure review thresholds and Key 2 risk clearance.
10. **Are Microsoft Graph write permissions required?** No; optional M365 write capabilities are disabled by default, and local `Bind a roster identity` works without them.

Glossary

Term	Plain-English Definition
Dual-Key Acceptance	Onboarding control requiring Key 1 (client acceptance of exact proposal revision) + Key 2 (staffed Partner unconditional risk clearance) + paid 50% advance before engagement activation.
Engagement	A single audit, assurance, or accounting project for a client and financial period.

Term	Plain-English Definition
EQR (Engagement Quality Review)	Independent quality concurrence by a `Partner` who is not the Engagement Partner.
FSLI (Financial Statement Line Item)	Standardized reporting line to which client trial balance accounts are mapped.
LOR (Letter of Representation)	Signed representation letter from client management verified by the `Partner` prior to opinion issuance.
Maker-Checker	Server rule requiring that the preparer (`User A`) and reviewer/approver (`User B`) are two distinct user accounts.
PBC (Provided by Client)	Information and document requests answered by `ClientUser` contacts in `/portal`.
Role Grant	Database record linking a user, a role code, a scope, an effective timestamp, and an optional expiry timestamp.
Roster Identity	Pre-registered user record created via `Bind a roster identity` before the person's first Microsoft sign-in.
Scope	Where a grant applies: `FIRM_WIDE`, `CLIENT`, `ENGAGEMENT`, or `GROUP`.
Session Epoch	Counter incremented on every grant change or revocation to invalidate stale browser sessions immediately.
SRM (Significant Risk / Materiality)	Planning materiality and significant risk record locked by the `Partner`.
TB / GL	Client Trial Balance and General Ledger imported for audit fieldwork and R2R financial statements.

13. Appendices (Administrator Walkthrough & Source Evidence Map)

Appendix A: Administrator Walkthrough (`Administration → Users & Access`)

For the AuditSphere Administrator (`Administrator@FIRM_WIDE`) operating `/app/admin/access` and `/app/admin/directory`:

1. **Search local users:** Filter existing accounts by name, email, role, or status. Each card shows active grant badges (formatted via `codeLabel`), `SessionEpoch`, `Copy invitation link`, `Revoke`, and `Disable user` / `Enable user`.
2. **Bind a roster identity:** Pre-register a user before first sign-in with `Work email` (exact Entra UPN, max 320 chars), `Display name`, `User type` (`STAFF` or `CLIENT`), linked `Client` (required for `CLIENT`), `Binding source` (`APPROVED_ROSTER` or `VERIFIED_SIGN_IN`), and optional `External subject ID` / `External tenant ID`.
3. **Assign role and scope:** Select the user, choose the role in `#local-role` (10 staff roles for `STAFF`; `ClientUser` for `CLIENT`), pick the scope (`FIRM_WIDE`, `CLIENT`, `ENGAGEMENT`, or `GROUP`), set optional `Expires at` (>= 5 mins in future; leave blank for `GROUP`), and enter the required approval `Reason`.
4. **Copy invitation link:** Click `Copy invitation link` on the grant row to copy the `/api/ui/administration/access/invitations/{id}` URL.
5. **Optional Microsoft administration & Microsoft directory:** Capabilities `TENANT_USER_PROVISIONING` (`User.Create`), `GUEST_INVITATION` (`User.Invite.All`), and `GROUP_MEMBERSHIP` (`GroupMember.ReadWrite.All`) are disabled by default (`NOT_GRANTED` / `BLOCKED_EXTERNAL` in `status.json`) until tenant admin Graph consent is granted and verified. Local roster binding works without them.

Appendix B: Source Evidence Map, Non-Assignable Codes & Open Questions (`TO CONFIRM`)

Non-Assignable Backend Guard Role Codes: Seven legacy/guard codes appear in backend `RequiredRoles` arrays (`Reviewer`, `SeniorManager`, `EngagementLeader`, `Auditor`, `Accountant`, `CommercialManager`, `RecordsCustodian`) but are not in `RoleAdministrationService.AllowedRoles` and cannot be granted to users. Engagement staffing levels (`ENGAGEMENT_PARTNER` rank 4, `AUDIT_MANAGER` rank 3, `SENIOR_AUDITOR` rank 2, `STAFF_ASSOCIATE` rank 1) are engagement staffing allocations in `ResourcePlanning.cs`.

ID	Topic	Observed Code Behavior	Open Question (`TO CONFIRM`)
TC-01	Personal Email Domains & Shared Mailboxes	`RoleAdministrationService.EmailLike` checks only for a single `@`, no whitespace, and length <= 320.	`TO CONFIRM`: Should firm policy reject consumer domains (`@gmail.com`) or shared mailboxes (`finance@example.com`)?
TC-02	Invitation Link Expiration (TTL)	`GetInvitationLinkAsync` has no separate link TTL timer; link stays valid while the `RoleGrant` is active.	`TO CONFIRM`: Should copyable invitation links expire after a set window (e.g., 72 hours) if unused?
TC-03	Administrator Turnaround SLA	Grant activation is immediate once saved in UI, but human processing time is operational.	`TO CONFIRM`: What turnaround SLA (e.g., 1 business day) should be promised in Sections 1 & 10?
TC-04	Oversight Expiry & Reviewer Policy (`D-OV-04`)	`Administrator@FIRM_WIDE` logs immutable `AdministratorOversightAccessEvent` on 13 GET queries.	`TO CONFIRM`: Owner decision `D-OV-04` on oversight window expiry and independent review of Oversight History.
TC-05	Live Entra / Graph Consent (`BLOCKED_EXTERNAL`)	`docs/execution/status.json` marks live Graph provisioning gates as `BLOCKED_EXTERNAL`.	`TO CONFIRM`: Which deployment tenants will enable optional Graph write capabilities vs. local roster binding only?